HOCHSCHULE MAINZ
Wirtschaft
Business

Resilienz als Organisationsfähigkeit

Cyber Security Management · Termin 5

Prof. Dr. Dirk Loomans

University of
Applied Sciences

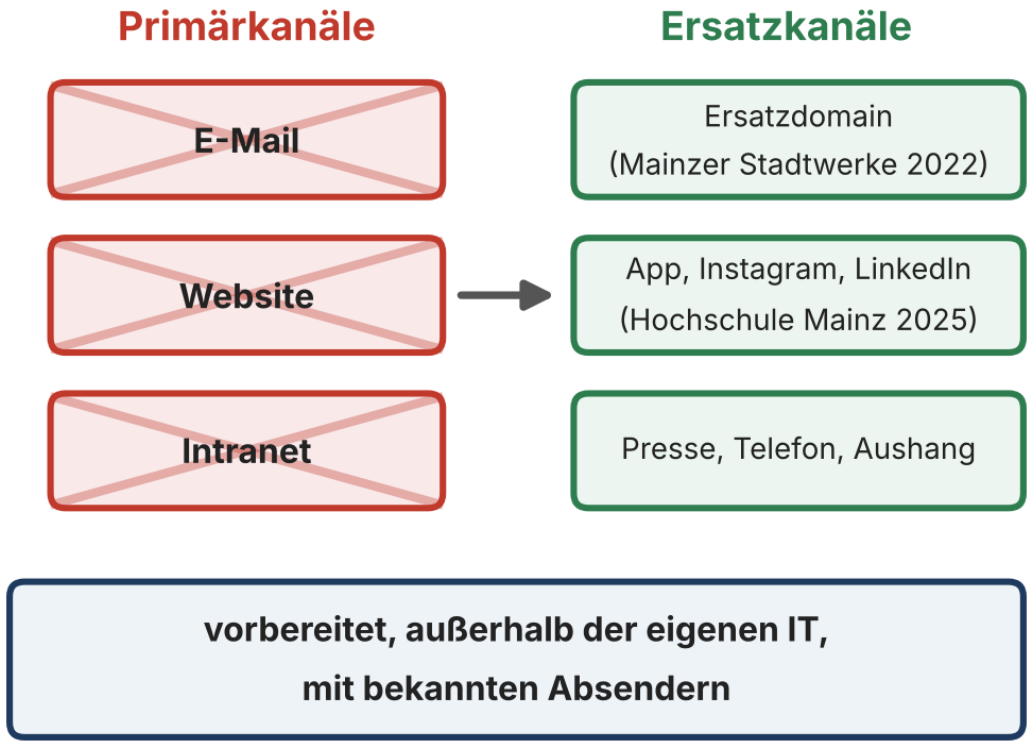
Agenda

- Rückblick & Lernziele
- Einstieg: Norsk Hydro – die Organisation trägt
- Organisationale Resilienz und Resilienzzyklus
- Rollen, Krisenstab und Entscheidungslogik
- Kommunikation unter Stress · Schulz von Thun
- Incident-Response-Prozess
- Übungskultur und Governance
- Gruppenübung · Kultur & Lernen
- Kernpunkte & Ausblick

Rückblick Sitzung 4

- Resilienz ist **relational** – resilient gegen eine konkrete Bedrohung
- Sechs Bedrohungsklassen, unterschieden nach ihrem **Effekt**
- Dienstleister und Identität als **gemeinsame Fehlerpfade** (KDZ/KGRZ 2026, Azure AD 2021)
- Vorsorgliches Abschalten und Notkommunikation als **Resilienzentscheidungen**

Jede dieser Entscheidungen hat jemand getroffen. Heute geht es um diese Menschen und Strukturen.



Lernziele

Nach dieser Sitzung können Sie …

– erklären, was **organisationale Resilienz** nach ISO 22316 ist und aus welchen Komponenten sie besteht,
– den **Resilienzzyklus** und den **Incident-Response-Prozess** organisatorisch beschreiben,
– begründen, warum Krisen **Rollen statt Personen** und Entscheidungskompetenz auf Zeit brauchen,
– Kommunikation unter Stress mit **CCCC** und dem **Vier-Seiten-Modell** analysieren,
– an realen Fällen zeigen, wie **Übung, Governance und Lernkultur** Resilienz verankern.

Einstieg: Norsk Hydro 2019

- **19. März 2019:** Ransomware LockerGoga trifft den Aluminiumkonzern – rund 35.000 Beschäftigte in 40 Ländern
- Anlagen werden **isoliert**, wo möglich wird **manuell** weitergearbeitet
- Noch am selben Tag: **Pressekonferenz** mit Webübertragung, danach laufende Updates
- **Kein Lösegeld** – Wiederaufbau aus Backups; Gesamtkosten nach Hydro rund 800 Mio. NOK

Frage: Warum gilt ein Unternehmen mit lahmgelegter IT als Vorbild für Resilienz?



Technik schafft Potenzial

Technische Resilienz sichert **Systeme**, organisationale Resilienz sichert **Entscheidungen**. **Im Ernstfall entscheidet nicht Technologie, sondern Verhalten.**

Aspekt	Technische Resilienz	Organisationale Resilienz
Steuerungslogik	deterministisch, automatisiert	adaptiv, situativ
Fokus	Systeme und Prozesse	Menschen, Rollen, Kommunikation
Nachweis	Monitoring, Failover-Tests	Übungen, Entscheidungswege, Lernfähigkeit
Zielgröße	System bleibt funktionsfähig	Organisation bleibt handlungsfähig

Was ist organisationale Resilienz?

ISO 22316:2017: die Fähigkeit einer Organisation, **in einem sich wandelnden Umfeld Störungen aufzufangen und sich anzupassen**, um ihre Ziele zu erreichen, zu überleben und zu gedeihen.

- **Strukturen** → klare Rollen und Verantwortlichkeiten
- **Prozesse** → Detection, Reaktion, Wiederanlauf
- **Menschen** → Ausbildung, Training, Entscheidungsfähigkeit
- **Kultur** → Fehleroffenheit und Lernfähigkeit



Der Resilienzzyklus

- **Detection:** Früherkennung – technisch (SIEM) und organisatorisch (Meldekultur)
- **Response:** Sofortmaßnahmen und Schadensbegrenzung entlang einer gemeinsamen Lage
- **Recovery:** Wiederanlauf nach Business Impact, nicht nach Zufall
- **Adapt:** Lernen und Optimieren nach jedem Ereignis

Bezug: ISO 22316 · ISO/IEC 27035 · BSI-Standard 200-4



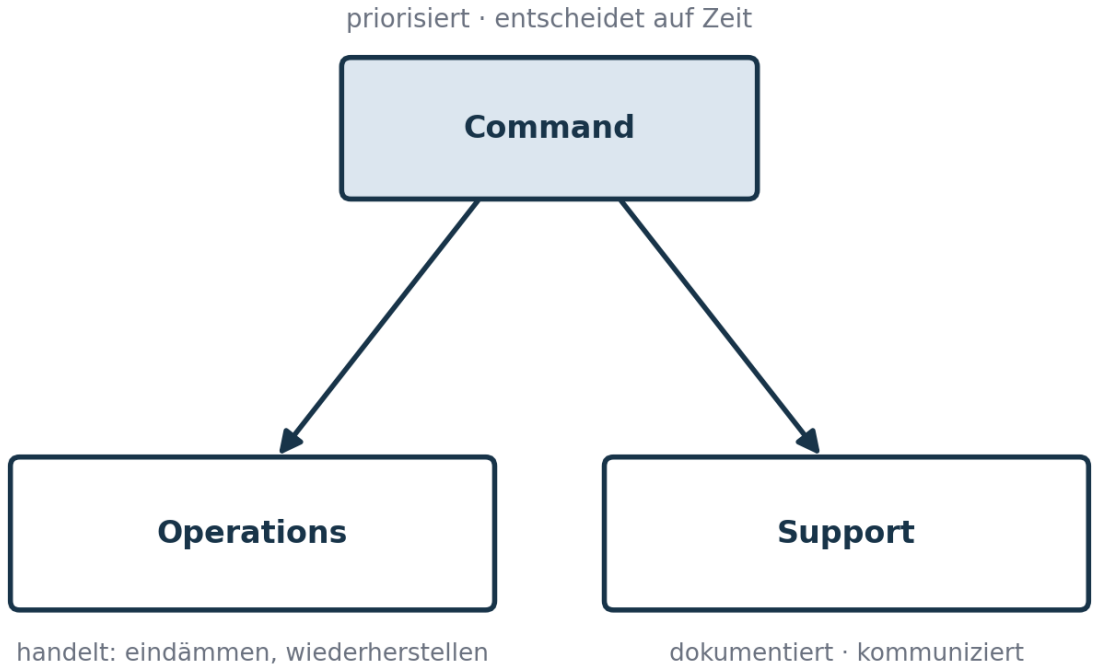
Rollen statt Personen

Kernprinzip: **Wer entscheidet was, wann und warum?**

Rolle	Hauptaufgabe
CISO	Strategische Leitung, Entscheidung über Eskalationsstufen
Incident Commander	Operative Gesamtkoordination im Ereignisfall
IT Operations / Technical Lead	Analyse, technische Eindämmung und Wiederherstellung
BCM-Manager	Koordination mit Fachbereichen, kritische Prozesse zuerst
Kommunikation / PR	Interne und externe Information
Legal / Datenschutz	Meldepflichten, etwa Art. 33 DSGVO
Management Board	Ressourcen, Business-Priorisierung, Risikoakzeptanz

Entscheidungslogik in Krisen

- Der Linienweg ist zu langsam: **Entscheidungskompetenz auf Zeit** (Incident Command System)
- Command priorisiert · Operations handelt · Support dokumentiert und kommuniziert
- **Unity of Command** · **Span of Control** (5–7) · Delegation · Nachvollziehbarkeit · Training
- Unter Stress greifen Menschen auf erlernte Muster zurück – **Playbooks und Entscheidungsbäume bereiten Entscheidungen vor**

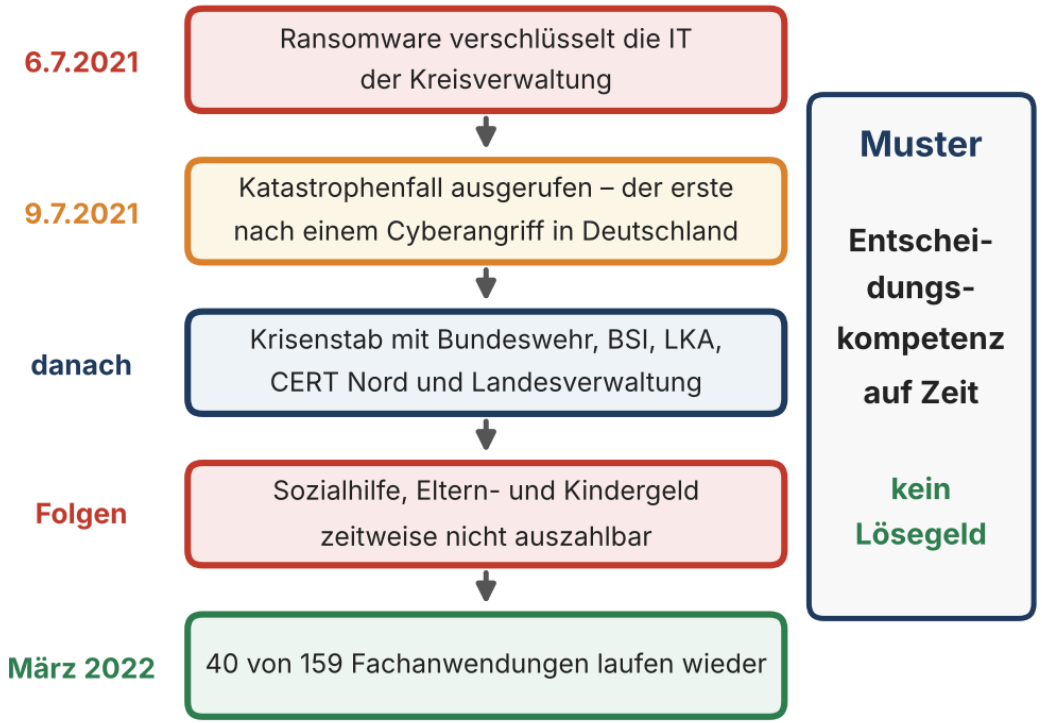


Unity of Command · Span of Control 5–7 · Delegation

Fallbeispiel: Anhalt-Bitterfeld 2021

- **6. Juli 2021:** Ransomware verschlüsselt die IT der Kreisverwaltung, nur die Telefonanlage läuft
- **9. Juli:** Der Landkreis ruft den **Katastrophenfall** aus – der erste nach einem Cyberangriff in Deutschland
- **Krisenstab** mit Bundeswehr, BSI, LKA, CERT Nord und Landesverwaltung
- Sozialhilfe, Eltern- und Kindergeld zeitweise nicht auszahlbar; im März 2022 liefen erst **40 von 159** Fachanwendungen

Kein Lösegeld – aber über ein halbes Jahr Katastrophenfall.



Kommunikation unter Stress

Krisenkommunikation ist Teil der Resilienzarchitektur.

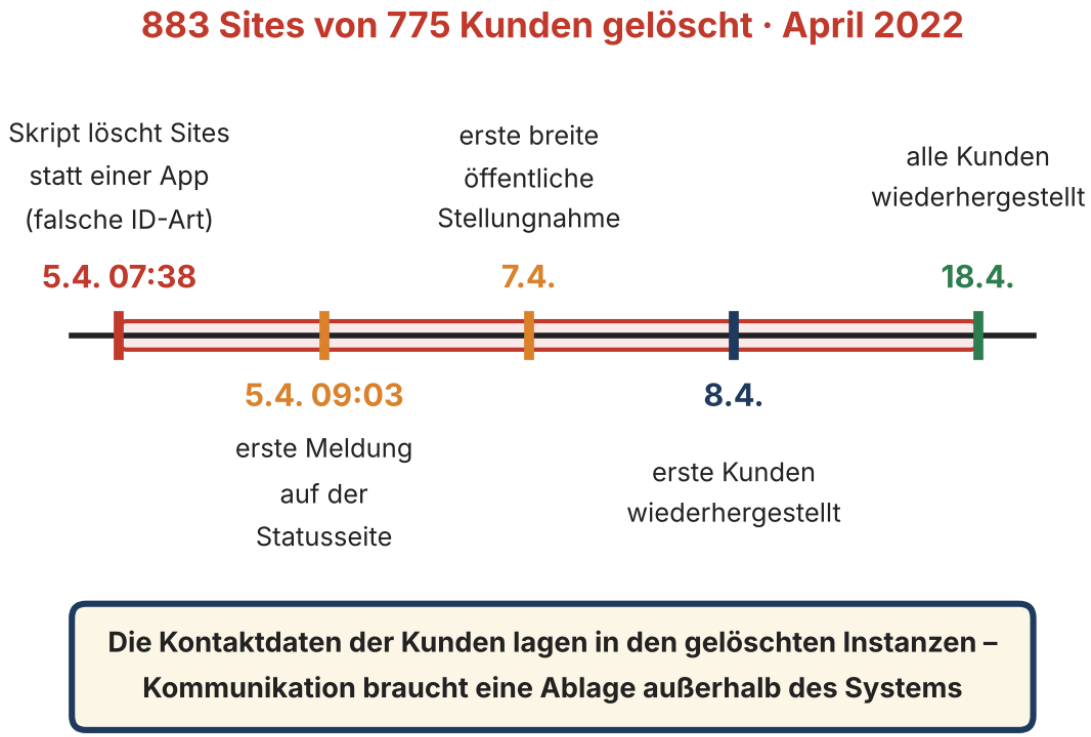
- Viele Vorfallsbehandlungen scheitern an **Informationsfehlern**, nicht an Technik.
- Prinzipien: **Clear · Concise · Confirmed · Coordinated**
- „Eine Info ist nur so gut wie ihre Bestätigung."
- Kanäle **und Kontaktlisten** müssen vorher definiert, getestet und außerhalb der betroffenen Systeme verfügbar sein.



Fallbeispiel: Atlassian 2022

- **5. April 2022:** Ein Wartungsskript löscht **883 Sites von 775 Kunden** – es erhielt Site-IDs statt App-IDs
- Mit den Sites verschwinden die **Kontaktdaten** der Kunden-Admins
- Statusseite nach knapp anderthalb Stunden, eine breite öffentliche Stellungnahme erst **am dritten Tag**
- Wiederherstellung bis **18. April** – RPO eingehalten, RTO verfehlt

Atlassian selbst: Wir hätten viel früher breiter kommunizieren müssen.



Exkurs: Kommunikation nach Schulz von Thun

Jede Botschaft hat vier Ebenen. Beispiel im IT-Incident – Admin sagt: „Der Server ist schon wieder down.“

Ebene	Frage	Botschaft
Sachinhalt	Worüber informiere ich?	Der Server ist nicht erreichbar.
Selbstoffenbarung	Was zeige ich von mir?	Ich bin genervt und gestresst.
Beziehung	Was halte ich vom anderen?	Ihr hättet das früher merken müssen.
Appell	Was will ich erreichen?	Bitte tut endlich etwas!

Kommunikationsübung: Vier Seiten einer Nachricht

3er-Gruppen, 10 Minuten. Analysiert die Aussage aus einer Incident-Situation:

„Warum habt ihr das Backup noch nicht eingespielt?“

- Welche Botschaften stecken in den vier Ebenen?
- Wie könnte dieselbe Aussage resilienter formuliert werden?
- Welche Missverständnisse entstehen, wenn nur eine Ebene gehört wird?
- Welche Kommunikationsregeln helfen, in Stresslagen klar zu bleiben?

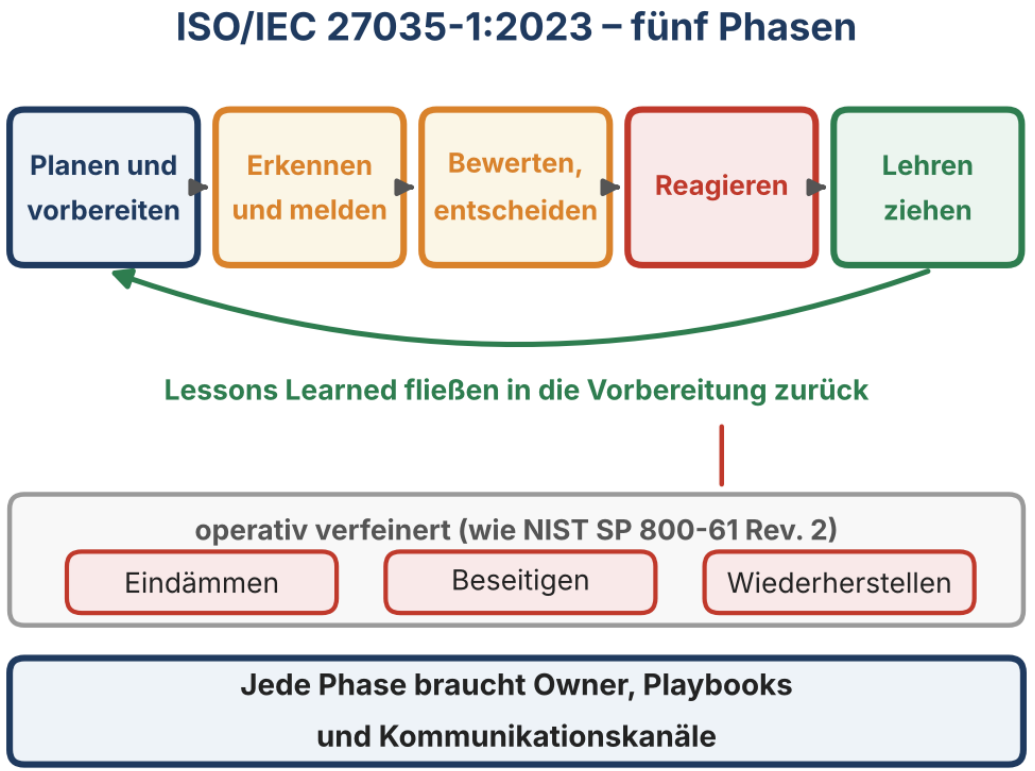


Incident-Response-Prozess

ISO/IEC 27035-1:2023 gliedert in fünf Phasen:

1. **Planen und vorbereiten**
2. **Erkennen und melden**
3. **Bewerten und entscheiden** – Triage, Kritikalität
4. **Reagieren** – eindämmen, beseitigen, wiederherstellen
5. **Lehren ziehen** – zurück in die Vorbereitung

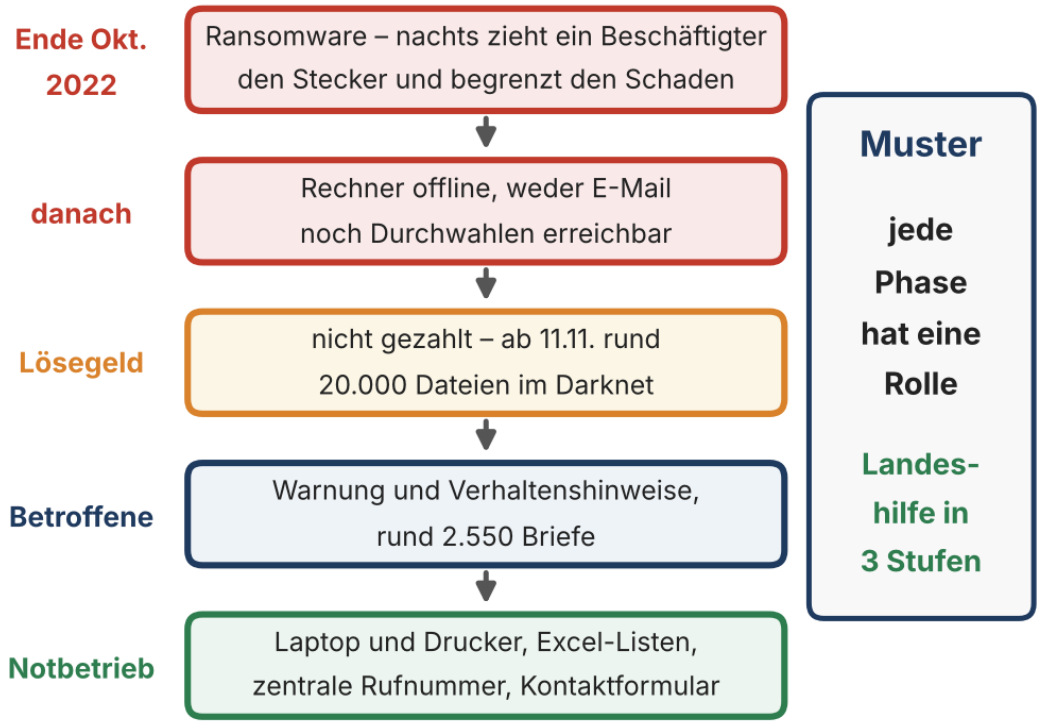
Jede Phase braucht definierte Owner, Playbooks und Kommunikationskanäle.



Fallbeispiel: Rhein-Pfalz-Kreis 2022

- **Ende Oktober 2022:** Ransomware in der Kreisverwaltung in Ludwigshafen – ein Beschäftigter zieht nachts den Stecker
- Rechner offline, **weder E-Mail noch Durchwahlen** erreichbar; Notbetrieb mit Laptop, Drucker und Excel-Listen
- Lösegeld nicht gezahlt – ab 11. November rund **20.000 Dateien im Darknet**, Warnung an rund 2.550 Betroffene
- Ersatzkanäle: **zentrale Rufnummer, Kontaktformular**, Personal vor Ort in den Gemeinden

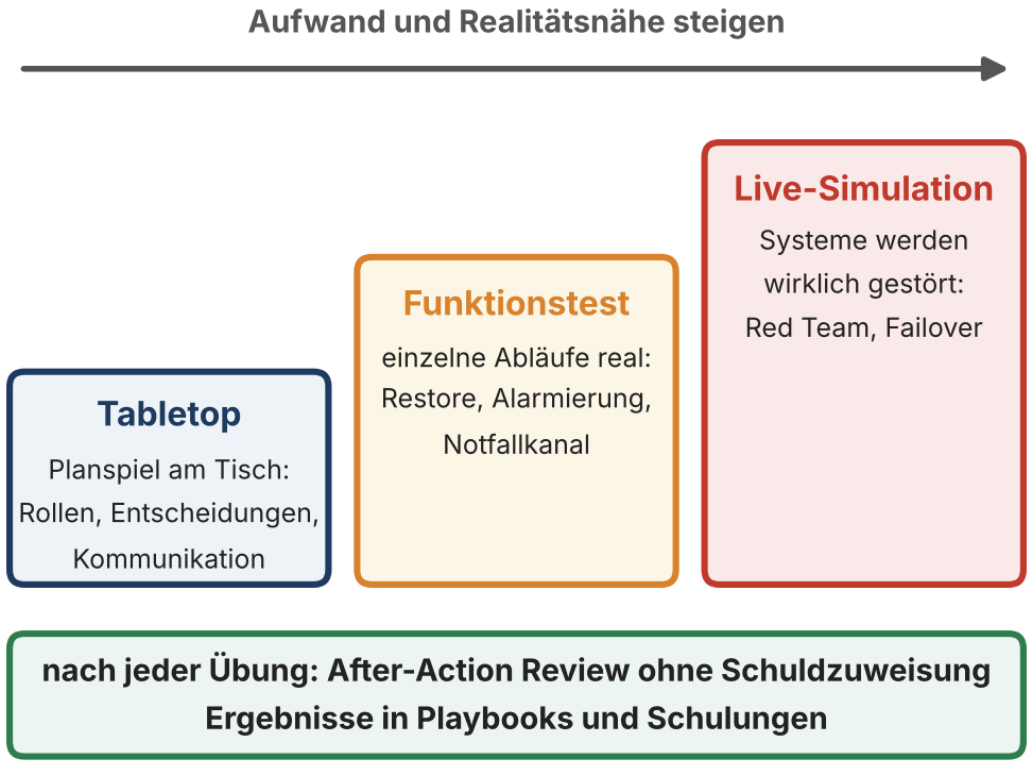
Erkennen, entscheiden, reagieren, informieren – jede Phase braucht eine Rolle.



Übungs- und Trainingskultur

Resilienz ist keine Theorie – sie entsteht durch Übung.

- **Tabletop-Übungen:** Planspiel, Fokus auf Kommunikation und Entscheidungswege
- **Live-Simulationen:** technische Reaktionsfähigkeit unter Realbedingungen
- **After-Action Reviews:** strukturiertes Feedback, keine Schuldzuweisung
- **Metriken:** Time to Detect · Time to Decision · Time to Recover · Übungshäufigkeit



Fallbeispiel: LÜKEX 23

- **27.–28. September 2023:** Krisenmanagementübung von Bund und Ländern unter Federführung des BBK
- Szenario: **Cyberangriff auf das Regierungshandeln**
- Mehr als **50 Behörden** und **1.000 Mitwirkende**, acht Länder voll beteiligt; monatelange Vorbereitung
- Geübt: **Melde- und Kommunikationswege**, Zusammenspiel von Krisen- und IT-Notfallmanagement, Krisenkommunikation

Übung im großen Maßstab – ohne einen einzigen Server abzuschalten.



Resilienz-Governance

„Resilienz ist keine Projektaufgabe, sondern Führungsverhalten.“

Managementsystem	Bezug zur Resilienz
ISMS (ISO/IEC 27001)	Struktur für Informationssicherheit und Incident Management
BCMS (ISO 22301)	Kontinuität kritischer Geschäftsprozesse
Risk Management (ISO 31000)	Identifikation und Bewertung von Bedrohungen
Crisis Management (ISO 22320)	Entscheidungs- und Kommunikationsstrukturen im Ereignisfall
Resilience Management (ISO 22316)	verbindet die Systeme zu einer adaptiven Gesamtstruktur

Gruppenübung: Ransomware am Montagmorgen

Szenario: Montag, 08:15 Uhr. Mehrere File-Server sind verschlüsselt, eine Lösegeldforderung erscheint. Cloud-Sync ist betroffen, VPN und Mail laufen noch.
Gruppen, 15–20 Minuten:

1. Wer übernimmt die Incident-Leitung?
2. Welche Systeme oder Personen müssen sofort informiert werden?
3. Welche Entscheidungen sind in den ersten 30 Minuten kritisch?
4. Wie läuft die interne und externe Kommunikation?
5. Welche Priorität hat Recovery gegenüber Forensik?
6. Wann erfolgt die Meldung an Aufsichtsbehörden (DSGVO Art. 33 / NIS-2)?

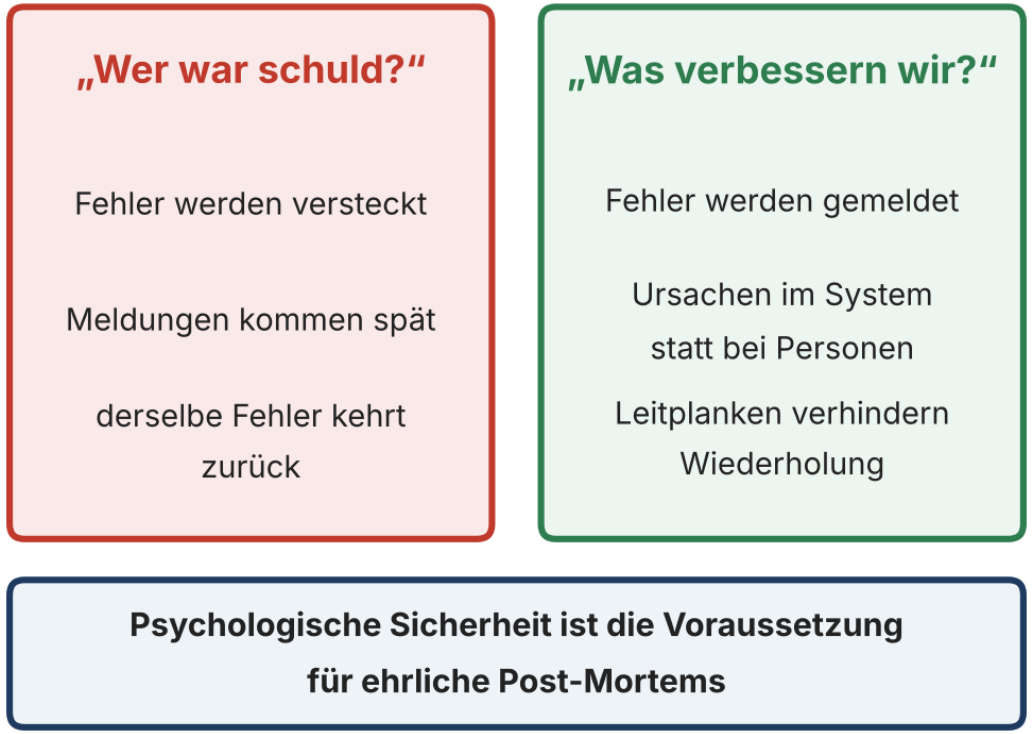
Typischer Verlauf und häufige Fehler

Phase	Beschreibung	Häufige Fehler
Detection	erste Hinweise, z. B. unzugängliche Daten	Unterschätzung der Lage, verspätete Eskalation
Response	Eindämmung, z. B. Netzwerksegmentierung	fehlende Koordination, doppelte Maßnahmen
Communication	interne und externe Information	Intransparenz, widersprüchliche Aussagen
Recovery	Wiederherstellung aus Backups	keine Priorisierung, ungetestete Backups
Adapt	Ursachenanalyse, Lessons Learned	keine systematische Nachbereitung

Kultur & Lernen

Resilienz ist ein soziales Phänomen.

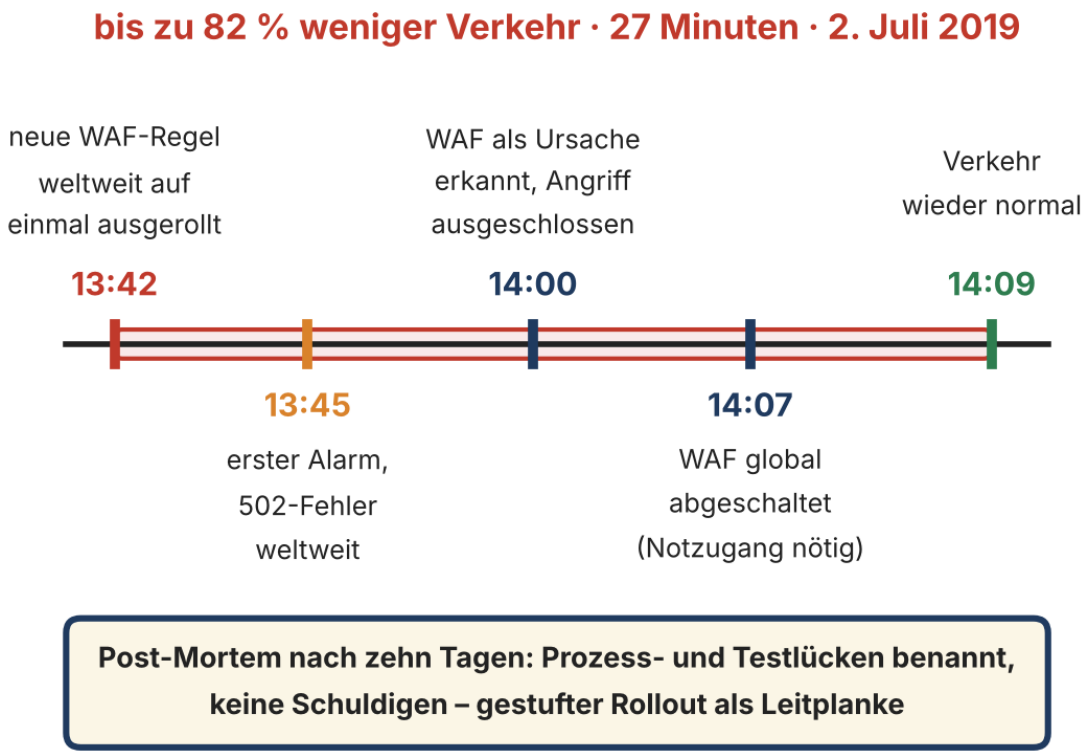
- **Blame-free Post-Mortems:** Statt „Wer war schuld?“ die Frage „Was verbessern wir?“
- **Psychologische Sicherheit** (Edmondson): Fehler und Unsicherheiten dürfen gemeldet werden
- **Transparente Kommunikation:** Fehler werden geteilt, nicht versteckt
- **Institutionelles Lernen:** Lessons Learned → Prozesse, Playbooks, Leitplanken



Fallbeispiel: Cloudflare 2019

- **2. Juli 2019, 13:42 UTC:** Eine neue Firewall-Regel mit fehlerhaftem regulärem Ausdruck geht **weltweit auf einmal** live
- Die CPUs laufen voll, der Verkehr bricht um **bis zu 82 %** ein; nach **27 Minuten** ist die Regel global abgeschaltet
- Auch interne Werkzeuge hängen am Netz – das Team braucht einen selten genutzten **Notzugang**
- Zehn Tage später: öffentliches **Post-Mortem** mit Zeitleiste, Prozessfehlern und Maßnahmen

Gefragt wird nach dem Prozess, nicht nach dem Schuldigen.



Was die Fälle zeigen

Fall	Komponente	Lehre
Norsk Hydro 2019	Kultur, Kommunikation	Offenheit und Handarbeit tragen, wenn die IT fällt
Anhalt-Bitterfeld 2021	Strukturen	Krisenstab: Entscheidungskompetenz auf Zeit
Atlassian 2022	Kommunikation	Kontaktdaten gehören außerhalb des Systems
Rhein-Pfalz-Kreis 2022	Prozesse	Jede Phase braucht eine Rolle, auch der Notbetrieb
LÜKEX 23	Menschen	Krisenstrukturen werden geübt, bevor sie gebraucht werden
Cloudflare 2019	Kultur	Post-Mortem ohne Schuldige, Leitplanken statt Appelle

Kernpunkte

- Organisationale Resilienz ist die Fähigkeit zur **koordinierten Reaktion** – die Technik schafft nur das Potenzial (Norsk Hydro).
- **Rollen statt Personen** und Entscheidungskompetenz auf Zeit machen Krisen führbar (Anhalt-Bitterfeld).
- Kommunikation ist Teil der Resilienzarchitektur – samt **Kontaktlisten außerhalb des Systems** (Atlassian).
- Der Incident-Response-Prozess braucht in jeder Phase **Owner, Playbooks und Kanäle** (Rhein-Pfalz-Kreis).
- Resilienz entsteht durch **Übung** und **Lernen ohne Schuldzuweisung** (LÜKEX 23, Cloudflare).

Ausblick & Hausaufgabe

Nächste Sitzung: Rollen und Verantwortlichkeiten in der Cyber-Organisation – CISO, SOC, CERT
Hausaufgabe: Erstellen Sie für Ihre Organisation (Hochschule, Arbeitgeber, Verein) eine **Rollenkarte für die ersten 60 Minuten** eines Ransomware-Vorfalls: Wer leitet? Wer darf Systeme abschalten? Wer informiert wen über welchen Kanal – und wo liegt die Kontaktliste, wenn E-Mail und Fileserver ausfallen?
Kapitel zum Termin · Skript · Glossar · Quellen